SafeLane AI Gateway — Project Documentation

Credify System Thinking Challenge 2026 · Challenge area 01: AI & Cybersecurity · Oct 28, 2026 · @Sibusiso

Summary

Organisations leak data into AI because the unsafe route is faster than the safe one. SafeLane is an AI gateway that makes the governed route the easiest one. Every prompt passes through it, and it does four things:

- **Register check.** Unapproved tools are blocked by default.
- **Redaction.** Personal data, credentials and internal codenames are stripped before anything leaves.
- **Human review.** Decisions about people or money go to a person first.
- **Audit.** Every request goes into a tamper-evident log.

Challenge area: 01, AI & Cybersecurity. *How can companies use AI without creating new security risks?*

Headline evidence. The prototype was first tested against prompts written to break it, then improved. It was then scored once on a held-out set that was written before the improvements. On that set:

- Decision accuracy rose from 45% to 95%.
- Sensitive values that would have reached an external model fell from 10 of 10 (a policy-only approach) to 1 of 10.
- The policy check adds about 0.07 ms per prompt.

All test data is synthetic, and the remaining miss is reported rather than patched (section 7).

1. Problem and context

Staff are adopting AI faster than their organisations can govern it, and the data goes with them. In a January 2025 survey of 1,000 US employees at large companies, 57% admitted entering sensitive information into public AI assistants and 68% used personal accounts. 22% still used personal accounts even when their employer gave them an approved tool (TELUS Digital). That last figure is the important one: **providing a tool is not enough if the tool is not the easiest option.**

It is costly. IBM's 2025 breach study found that a high level of shadow AI (AI used without approval or oversight) added about USD 670,000 to the average breach. 63% of the 600 organisations studied had no AI governance policy, and 97% of those with an AI-related incident lacked proper AI access controls (IBM).

It happens to sophisticated companies. In 2023 Samsung engineers pasted internal source code and meeting notes into ChatGPT within weeks of being allowed to use it. Samsung's response was a company-wide ban while it built internal tools (The Register; Business Today).

In South Africa it is also a legal exposure. Under POPIA, section 19 requires reasonable technical and organisational safeguards for personal information. Section 72 restricts sending personal information to a third party outside the country unless adequate protection applies (DataGuidance; MJ Kotze Inc). Most popular AI assistants are hosted offshore, so a staff member pasting a customer's ID number into a chatbot is a cross-border transfer the organisation never approved.

Who is affected:

- **Customers and citizens**, whose data is exposed.
- **Staff**, who carry the blame for an unclear rule.
- **The organisation**, which carries the regulatory, financial and reputational cost.

State-owned and regulated entities are especially exposed: they hold citizen data, operate critical infrastructure, and face public scrutiny when things go wrong.

2. Stakeholders

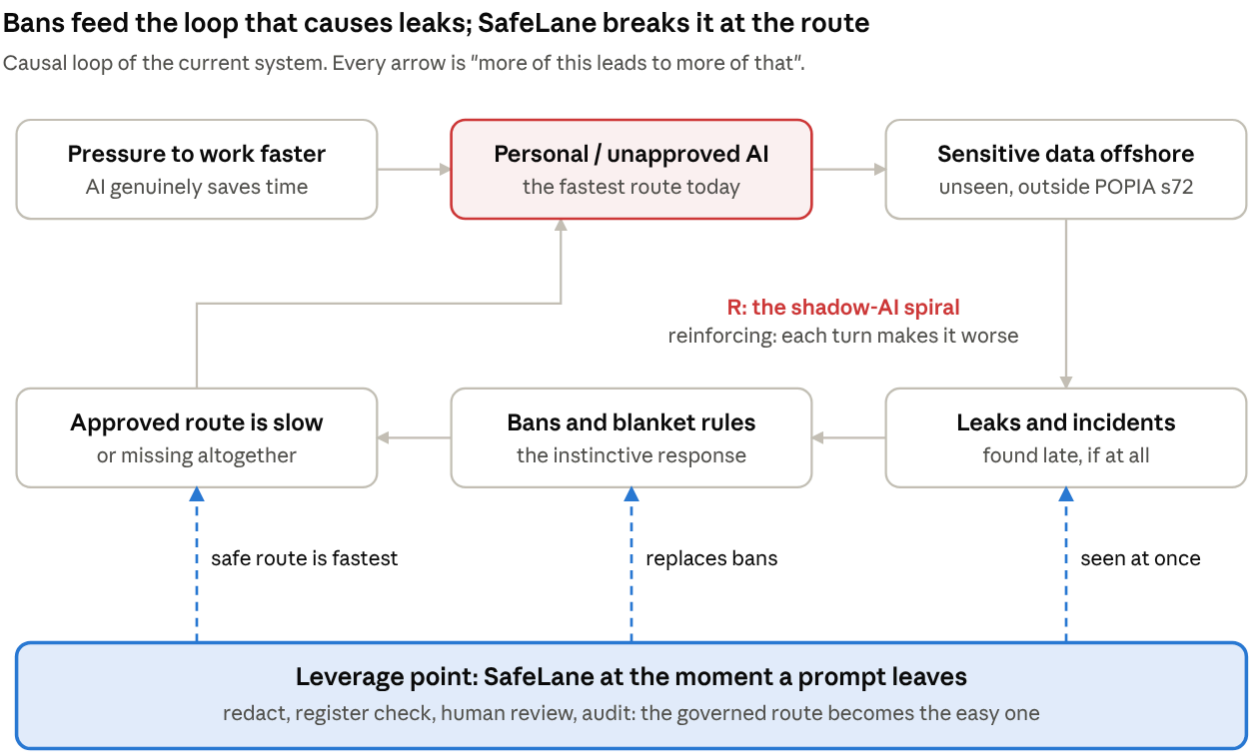
The people who feel the risk are not the people who feel the time pressure, and the people with the power to fix it see neither. That mismatch is why the problem persists.

Stakeholder	What they want	Incentive today	Power to change it
Front-line staff (writing, analysis, coding)	Get work done faster	Pasting into a personal chatbot saves time and nobody sees it	Low individually, high collectively: their habits *are* the system
Line managers	Output and deadlines	Many quietly accept shortcuts that hit targets	Medium: they set the pace and the norms

Stakeholder	What they want	Incentive today	Power to change it
CIO / IT	Secure, supportable tools	Default to blocking, which is simplest to defend	High: owns the network, the tools register and procurement
Information security	No incidents	Sees AI as new attack surface; often lacks visibility	Medium: can block, rarely can enable
Information Officer / legal (POPIA)	Lawful processing, no cross-border surprises	Usually learns about AI use after the fact	Medium: policy authority, little technical control
Executives / board	Productivity gains *and* no headlines	Pressure to "do AI" fast	High: budget and risk appetite
Customers and citizens (data subjects)	Their data stays protected	No voice in tool choices	Low directly; high via the Information Regulator and media
AI vendors	Usage and data	Consumer tiers may retain prompts	Medium: they set retention and hosting terms
Auditors / regulator	Evidence of control	Ask "show me", not "tell me"	High at audit time

3. How the current system works

The current system is a reinforcing loop: the usual response to AI leaks (ban it, tighten the rules) makes the approved route slower, which pushes more use into the shadows, which causes more leaks.



System map · causal loop of the current system and the leverage point

Work pressure creates real demand for AI. When the approved route is slow or missing, staff take the fastest route: a personal account on a public chatbot. Data goes offshore where nobody can see it, so incidents surface late. Leadership responds with bans or blanket rules, which make the approved route even less attractive, and the loop turns again. Samsung's 2023 leak-then-ban is this loop in action (section 1). A second loop runs alongside it: the more AI use moves to personal devices, the less the organisation can see, so its controls get aimed at the wrong place. **Breaking the loop means changing the route itself, not adding more rules on top of it** (section 5).

4. Root causes and key assumptions

The visible problem is "staff paste sensitive data into AI". That is a symptom of six causes, and most of them are about design rather than discipline.

Symptom people see	Root cause underneath
Staff use personal chatbot accounts	**Convenience gap.** The unsafe route is faster than the approved one, so time pressure wins every day.

Symptom people see	Root cause underneath
Leaks are found late or never	**Visibility gap.** The organisation cannot see AI use, so it cannot measure or manage it. Bans make it less visible, not less frequent.
"We told them not to paste sensitive data"	**Guidance gap.** The rule needs every person to classify data correctly, in the moment, under pressure. Abstract rules fail at the point of use. 44% of surveyed employees said their company had no AI guidelines or did not know if it did (TELUS, section 1).
Approved list exists but leaks continue	**Opaque supply chain.** Many "new" AI apps (PDF summarisers, note-takers, browser extensions) are wrappers sending data to a large hosted model. A list of product names misses where the data actually goes.
AI drafts used as decisions	**Verification erosion.** Fluent answers get trusted. Decisions about people (hiring, discipline, credit) drift from "AI-assisted" to "AI-decided" with no named owner.
Nobody can say who owns AI risk	**Split ownership.** IT owns tools, security owns threats, legal owns POPIA, managers own deadlines. No one owns the whole flow.

Key assumptions (what this analysis depends on, and how each would be tested):

Assumption	Why I believe it	How to test it
Most leakage is accidental, not malicious	Survey evidence and the Samsung case show productivity motives	Classify a sample of flagged prompts in a pilot by intent
Staff will use the governed route if it is as fast as the shortcut	22% bypass an approved tool even when they have one, which suggests convenience, not access, drives choice	Pilot: measure share of AI traffic through the gateway before and after, with network blocking held constant
Automated redaction catches enough to cut risk materially	Prototype held-out result: 9 of 10 sensitive values stopped	Independent red-team plus a consented sample of real prompts

Assumption	Why I believe it	How to test it
Reviewers can keep up with the HIGH queue	High-impact prompts should be a small share of traffic	Track queue volume and time-to-decision in the pilot; tune rules if the queue grows
Network controls can block the shortcut	Standard proxy/CASB capability	Confirm with infrastructure before rollout

5. Where the system can change

The leverage point is the moment a prompt leaves the organisation. It is the one place where convenience, visibility, guidance, supply chain and verification all meet. Change what happens there, and every other loop shifts.

Three interventions were considered:

	A. Ban public AI	B. Policy + training + approved list	C. Gateway (chosen)
What it changes	Removes access	Changes what staff know	Changes what happens to every prompt
Convenience gap	Wider: staff lose a useful tool	Unchanged	Closed: approved route is one screen, with redaction automatic
Visibility gap	Wider: use moves to personal phones	Unchanged	Closed: every request logged
Guidance gap	n/a	Narrowed, then decays	Closed at the point of use: the gateway classifies, explains and suggests an alternative
Supply-chain opacity	n/a	Partly, via the register	Closed: register records the underlying model; unlisted = blocked
Verification	n/a	Reminder only	High-impact prompts held for a named reviewer; answers labelled *draft only*

	A. Ban public AI	B. Policy + training + approved list	C. Gateway (chosen)
Cost and speed	Cheap, fast	Cheap, fast	Moderate: build or buy, then integrate
Main failure mode	Shadow AI on personal devices (Samsung-style)	"We trained them" while leakage continues	False confidence if detection is treated as perfect

Why C over B. B is necessary, but it relies on hundreds of people making a correct judgement every time under deadline pressure. C moves that judgement into the system. People then only decide the cases that genuinely need judgement (the HIGH queue). B's policy and training still matter: they explain *why* the gateway blocks something. So B is part of C, not an alternative to it.

Why not A. A ban treats the symptom and strengthens the shadow-AI loop. The organisation loses visibility *and* productivity.

6. The intervention: SafeLane

SafeLane puts four controls on the path every prompt already takes, so staff get their answer without having to become data-classification experts.

1. **Register check, default deny.** Each tool has a status: approved, restricted, not approved or prohibited. It also records the tool's hosting and the *underlying model vendor*, which closes the "wrapper app" loophole. An unlisted tool is blocked, and the user is pointed to an approved alternative instead of being left at a dead end.
2. **Detect and redact.** SA ID numbers (with checksum and date validation), card numbers (Luhn check), bank accounts, phone numbers, e-mails (including obfuscated ones), credentials (keys, JWTs, "password is …") and internal codenames are replaced with placeholders such as `[EMAIL_1]`. The real values stay in memory for that request only and are swapped back into the answer for the user. The external model never sees them.
3. **Risk tier.** Eight ordered rules produce LOW (send), MEDIUM (send redacted), HIGH (hold for a human) or BLOCKED (refuse, explain, suggest). Every decision records which rule fired. Credentials and injection attempts are always blocked. Prompts that ask the AI to decide about a person or money (hire, dismiss, approve a loan or claim) are always held. The reviewer sees only the redacted prompt and cannot approve their own request.

4. **Output checks and audit.** Answers are checked for sensitive data the user never sent, placeholders that were never issued (a sign of fabrication), and unverified links. Answers to high-impact prompts are labelled *draft only: a named person decides*. Every event is written to a SHA-256 hash-chained log that stores redacted text only, so the audit trail does not become a new leak, and any edit to history is detectable.

Design choices:

- **Rule-based detection, not an AI judging AI.** Rules are explainable to a reviewer, testable, fast and run fully offline. Their known blind spots are documented (section 7).
- **On-prem first.** Detection will never be perfect. Routing most work to a model on the organisation's own servers means a missed value stays inside. External tools are reserved for low-sensitivity work.
- **Explain, don't just block.** Every refusal says why and offers an approved route. Being blocked without an alternative is what drives people back to the shortcut.

Real-world grounding. The design draws on my own work at a South African state-owned entity. There I maintain an AI Tools Register (four statuses, unlisted = not approved, wrapper tools assessed against their underlying model) and am piloting an on-premises AI assistant with user accounts and conversation audit. A staff AI survey there ranked confidentiality, cybersecurity, unclear guidance and regulatory compliance as the top concerns. SafeLane is a generic, open version of that pattern, built on synthetic data. No employer code, data or infrastructure is included.

Prototype: Python, FastAPI, SQLite and a single-page web UI. It uses a mock model by default, or any OpenAI-compatible endpoint such as a local Ollama. It includes 16 automated tests. Setup and a screenshot walkthrough are in the repository README.

7. Evidence and testing

On prompts it was not tuned on, v2 stopped 9 of 10 sensitive values from reaching an external model and made the right call 19 times out of 20. The one miss is reported, not hidden.

Method. Three synthetic test sets, each with a different job:

1. **Templated (180 prompts).** Generated with a fixed seed. This is a regression check that the rules work on the formats they target. It is *not* evidence of real-world accuracy, because the rules and templates were written together.
2. **Adversarial (40).** Hand-written to break v1: spaced and international number formats, obfuscated e-mails ("name at domain dot com"), JWTs and bearer tokens, codename variants, isiZulu and Afrikaans phrasing, and hard negatives (invoice numbers, test cards, "kestrel" the bird). v2 was improved *using this set*.

3. **Held-out (20).** Written *before* the v2 changes and scored once, with no tuning on it.

Each prompt is labelled with the sensitive values it contains and the tier a policy owner would want. The "policy-only" baseline assumes nothing technical stops a paste, so every sensitive value reaches the external tool.

Test set	Version	Detection precision	Detection recall	Decision accuracy	Sensitive values reaching an external model
Held-out (20)	Policy only	n/a	n/a	n/a	10 of 10
Held-out (20)	v1	80.0%	40.0%	45.0%	5 of 10
Held-out (20)	**v2**	**88.9%**	**80.0%**	**95.0%**	**1 of 10**
Adversarial (40)	v1	70.0%	56.0%	52.5%	9 of 25
Adversarial (40)	v2, tuned on it	96.0%	96.0%	100%	0 of 25
Templated (180)	v2	100%	100%	100%	0 of 140

What the adversarial test taught me. v1 looked perfect on its own templates (100%) and fell to 52.5% on prompts written to break it. That gap is the real lesson: **a control tested only on the cases its author imagined will overstate its strength.** The v2 fixes were general patterns, not prompt-specific patches. For example, a hiring question now needs both a decision cue ("should we", "yes or no") *and* a person or money object. That stops the false alarm on "how should we hire better graduates?" without missing "should we hire Sipho?".

The held-out miss. `admin / P@ssw0rd2026`, a username and password with no "password" label, went through. In a utility this would be a control-system credential, the worst kind of miss. The fix (a credential-pair detector plus entropy scoring) was deliberately left out until after reporting, so the number above stays honest.

Speed. The policy check averaged about 0.07 ms per prompt over 4,800 evaluations on a 2-vCPU cloud sandbox. It adds no noticeable delay next to a model's response time, which matters because a slow safe route recreates the convenience gap.

Functional tests. 16 automated tests cover:

- Checksum validation and hard negatives.
- Default deny for unlisted tools.
- Blocking of secrets and prompt injection.
- The rule that a requester cannot approve their own request.
- Detection of tampering with a single audit row.

- An end-to-end check that personal data is restored for the user but never appears in what the model received or in the audit log.

All the results above come from running the code and data in the repository (`eval/`, `tests/`).

8. Feasibility

A mid-sized organisation could pilot this within one quarter, using skills and infrastructure it largely already has. The hard part is organisational, not technical.

Resources.

- **People:** one developer and one security/data person part-time for the build; named reviewers from HR and finance for the HIGH queue; the Information Officer to sign off the register rules.
- **Infrastructure:** one internal server for the gateway. The on-prem model needs its own server: a CPU-only box can run a small open-weight model for drafting and summaries, slowly, and a GPU is needed for more users or larger models.
- **Licences:** none required. The stack is open-source (Python, FastAPI, SQLite, open-weight models).

Implementation path.

1. **Weeks 1–4, foundations.** Agree the register and data classes with IT, security and legal. Add organisation-specific terms (project codenames, system names). Connect sign-in to the directory (SSO/Active Directory) so identities and reviewer roles are real.
2. **Weeks 5–8, pilot.** One or two departments (for example BI and HR) use the gateway as their AI front door. Measure everything in section 10. Red-team it with people who did not write the rules.
3. **Weeks 9–12, decide.** Tune the rules from pilot data, then decide whether to scale. Only then switch on network blocking of unapproved AI sites, so staff are never blocked before the good route exists.

Constraints.

- **The gateway only works if the shortcut is closed.** Without proxy or CASB rules blocking unapproved AI sites, staff can simply open a browser tab. That is a deployment dependency owned by IT.
- **Reviewer capacity.** If the HIGH queue grows faster than people can clear it, the safe route becomes slow and the shortcut returns. This needs a service level (e.g. same working day) and monitoring.

- **Cloud AI features built into other software** (office suites, CRM) do not pass through a gateway. They need their own contracts and settings, covered by the register.
- **Detection maintenance.** New data formats and codenames need rule updates, so the register owner needs a simple change process.

9. Risks, trade-offs and unintended consequences

The biggest risk is that a gateway creates false confidence. Most of the mitigations are about keeping people honest about what it cannot do.

Risk or side effect	Who it affects	Mitigation
False confidence. "The gateway catches everything", so people stop thinking	Whole organisation	Publish the miss rate; on-prem as the default route; training explains the limits; regular red-team
The gateway becomes a surveillance tool. A log of every prompt can be misused to monitor staff	Staff	Log stores redacted text only; access to the log restricted to an auditor role; a written purpose limit (security and compliance, not performance management); POPIA applies to staff data too
The audit log becomes a new leak	Data subjects	Raw values never written to disk; placeholders only; the reviewer also sees redacted text
Over-blocking slows work. False positives (e.g. a 13-digit meter serial that happens to pass ID checks) frustrate people	Staff	Context rules for reference numbers; every block explains why and offers a route; track false-positive reports as a pilot metric
The review queue becomes a bottleneck	Staff, reviewers	Narrow HIGH rules; a service level; rules tuned from data
Fairness. Rules written for English miss other languages, so isiZulu or Afrikaans speakers get weaker protection, or more false alarms	Staff and customers	Multilingual test cases in the evaluation (already started); review error rates by language in the pilot

Risk or side effect	Who it affects	Mitigation
Fairness in high-impact decisions. AI answers about hiring or discipline can carry bias	Candidates, employees	Those prompts are always held; answers labelled draft-only; a named person owns the decision and the reason
Single point of failure. Gateway down = no AI	Organisation	Fail *closed* to external tools, but keep the on-prem model available; monitor uptime
Adversarial users. Staff deliberately obfuscate data to get past rules	Organisation	Misuse patterns are logged as security events; network controls; a culture where the safe route is easier, so few people bother

The core trade-off: each extra rule improves safety and adds friction. If friction rises past the shortcut's, shadow AI returns. So **time-to-answer through the gateway** is tracked as a safety metric, not just a user-experience metric.

10. Expected impact and how success is measured

Success means more AI use, not less, with less of it going where nobody can see it. A pilot that cuts AI use has failed, even if it cuts leakage, because the demand will simply move to personal devices.

The targets below are pilot hypotheses to test, not results:

Measure	What it shows	Pilot target
Share of AI traffic through the gateway vs to unapproved AI sites (proxy logs)	Whether the safe route is winning	Rising month on month; most AI traffic by end of pilot
Sensitive values reaching external models, per 1,000 prompts	Actual exposure	Down sharply against a pre-pilot sample
Detection recall on a fresh, independently written red-team set	Whether the controls generalise	At least the held-out level (80%), and rising
Median extra time added by the gateway; HIGH-queue time-to-decision	Whether the safe route stays fast	No noticeable delay; HIGH decided the same working day

Measure	What it shows	Pilot target
False-positive reports per 1,000 prompts	Friction that drives people away	Falling after each rule update
High-impact decisions with a named human owner recorded	Accountability	All of them
Audit chain verification	Integrity of evidence	Passes every check
Staff survey: "I know which AI tools I may use and for what"	Whether the guidance gap is closing	Clear improvement from baseline

Longer term:

- For the organisation: fewer incidents, an audit trail a regulator can verify, and evidence-based decisions about which AI tools to approve next, because usage data shows demand.
- For staff: permission to use AI confidently instead of guiltily.

11. Limitations, next steps and disclosure

Limitations:

- Person names in free text are not detected, because there is no named-entity model yet.
- Unlabelled credentials are missed (the held-out miss).
- The test sets are small and self-written.
- The review queue is in memory, so pending reviews are lost on restart.
- The demo identity is a typed name, not a real sign-in.
- Output checks are heuristics: they flag problems, they cannot prove an answer is correct.
- The prototype has not been tested with real users.

Next steps, in order:

1. Add a credential-pair and entropy detector for the held-out miss.
2. Add an on-prem multilingual named-entity model behind the same interface.
3. Run an independent red-team.
4. Run a two-department pilot with the measures in section 10.
5. Add an encrypted review store and SSO.

Contribution and AI-assistance disclosure. I worked alone.

- **My contribution:** the problem framing and system analysis; the choice of leverage point and intervention; the register design (four statuses, default deny, closing the wrapper loophole, on-prem first, risk-tiered human review), taken from my own AI-governance work; the decision to test adversarially and report the held-out miss rather than patch it; and review and acceptance of all code and results.
- **AI assistance:** I used an AI assistant (Claude, by Anthropic) under my direction to write much of the code, generate the synthetic test sets and draft this document. Every number reported here comes from running the code in the repository.

Sources

- TELUS Digital survey, Feb 2025 (Business Wire): 57% entered sensitive data; 68% personal accounts; 22% bypass a provided tool; 44% unaware of or without guidelines
- IBM, 2025 Cost of a Data Breach: navigating the AI rush: USD 670,000 shadow-AI premium; 63% without AI governance; 97% lacking AI access controls
- TechRepublic on the IBM 2025 report: one in five organisations attributed a breach to shadow AI
- The Register, Apr 2023 and Business Today, May 2023: Samsung source-code leak and ban
- DataGuidance: Cloud regulation and POPIA and MJ Kotze Inc: cross-border data transfer agreements: POPIA sections 19, 21 and 72
- Prototype repository: SafeLane AI Gateway (`README.md` , `eval/README.md`)